FORTISAID LAB 8

Just-in-Time (JIT) VM Access – Attack Surface Reduction via Dynamic NSG Enforcement

1. Region + Resource Group

Region: West US 2
Resource Group: `fortisaid-lab05`
Virtual Machine: `FortisAid-VM-Private05`

2. Lab Objective

Enable and validate **Just-in-Time (JIT) VM access** using Microsoft Defender for Cloud to:

- Eliminate permanently open management ports
- Restrict inbound access to time-bound, IP-scoped requests
- Dynamically inject and remove NSG rules
- Reduce exposure to brute-force and lateral movement attacks

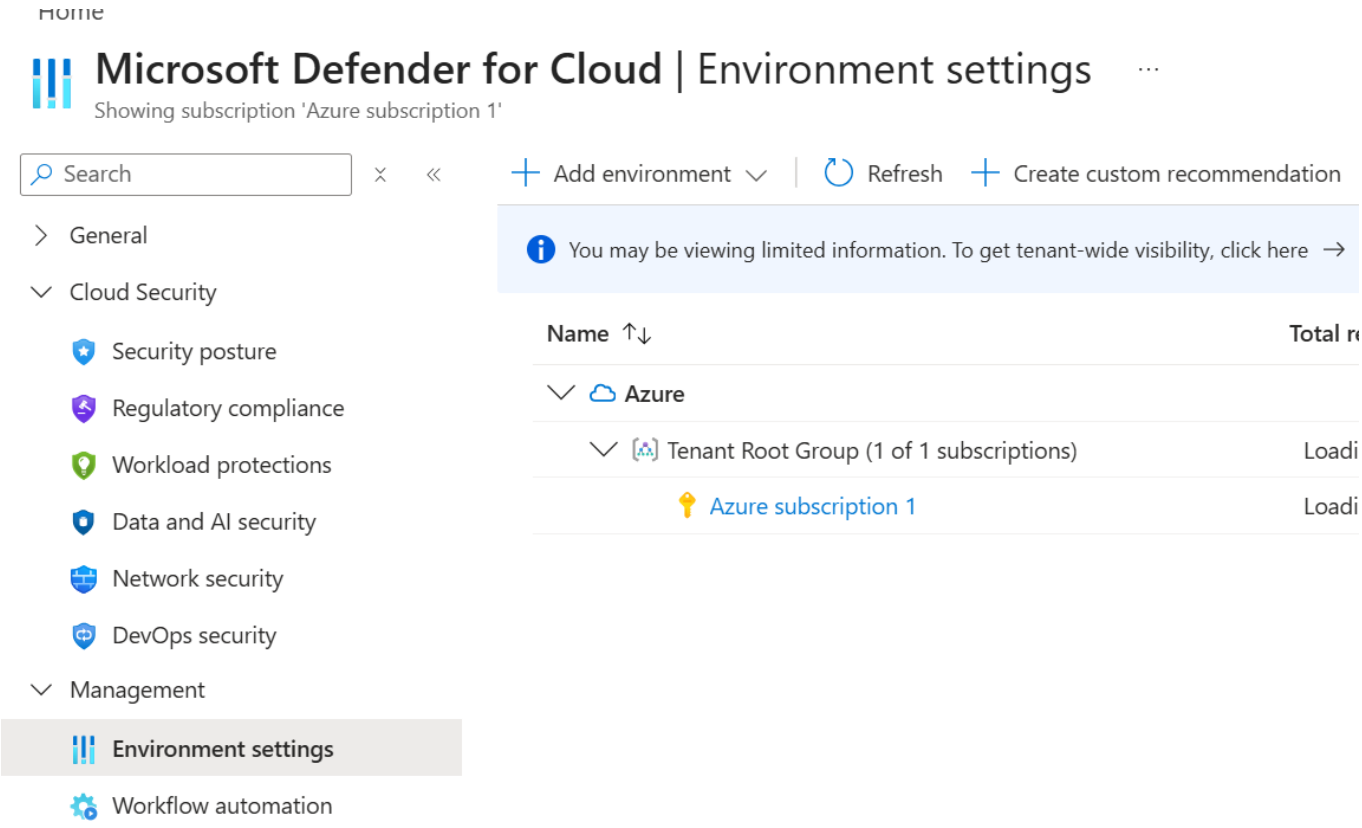
This lab builds on the prior Defender for Servers Plan 2 configuration.

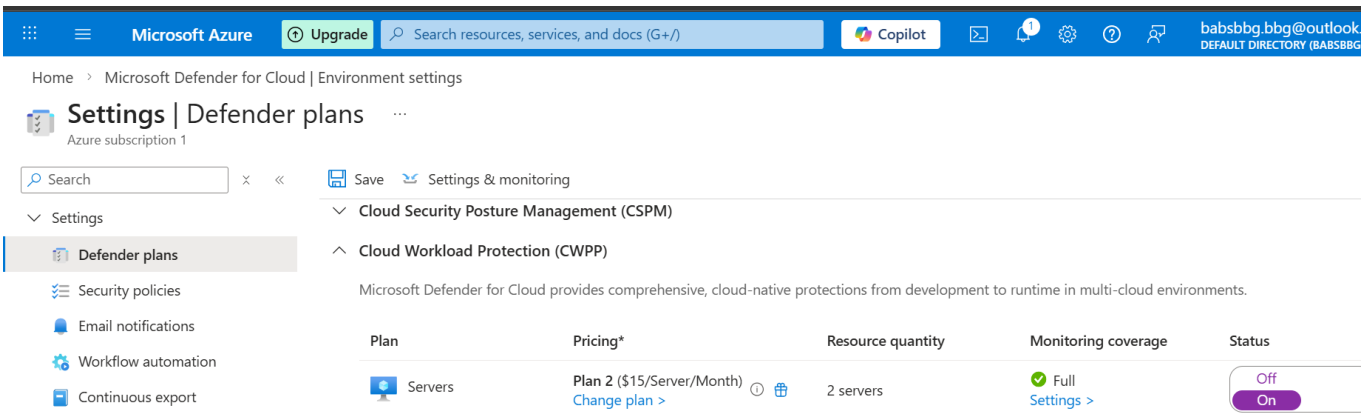
3. Pre-Validation (From Previous Lab)

Before enabling JIT, the following was confirmed in Lab 08:

- Defender for Servers Plan 2 = Enabled at subscription scope
- VM running in West US 2
- NSG attached to VM NIC
- Defender Inventory recognizes VM
- Workspace (`FortisAid-LAW`) configured

Verification





Defender plans showing Servers = On

Exercise 1 – Enable Just-in-Time VM Access

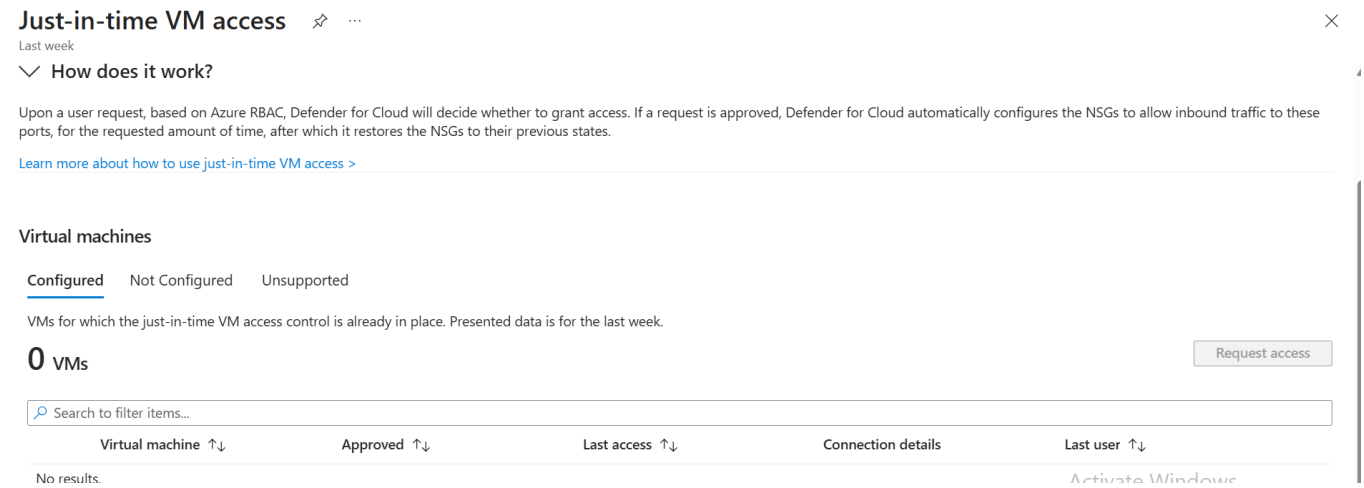
Step 1 – Open JIT Blade (Modern Path)

1. Azure Portal → Search:

   `Microsoft Defender for Cloud`
2. Select **Workload protections**
3. Select **Just-in-time VM access**

Verification

- JIT blade loads successfully
- Tabs visible:
  - Configured
  - Not Configured
  - Unsupported



JIT blade showing Configured / Not Configured tabs

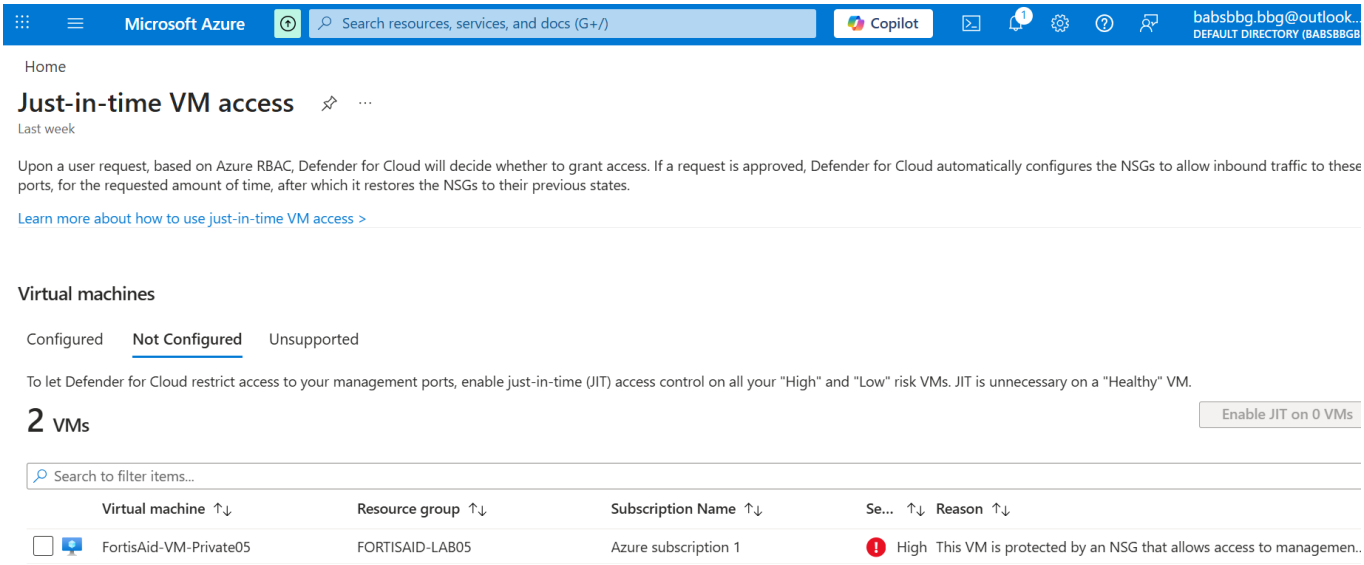
Step 2 – Identify VM Under Not Configured

1. Select **Not Configured** tab
2. Locate:

   `FortisAid-VM-Private05`

Verification

- VM appears under Not Configured list



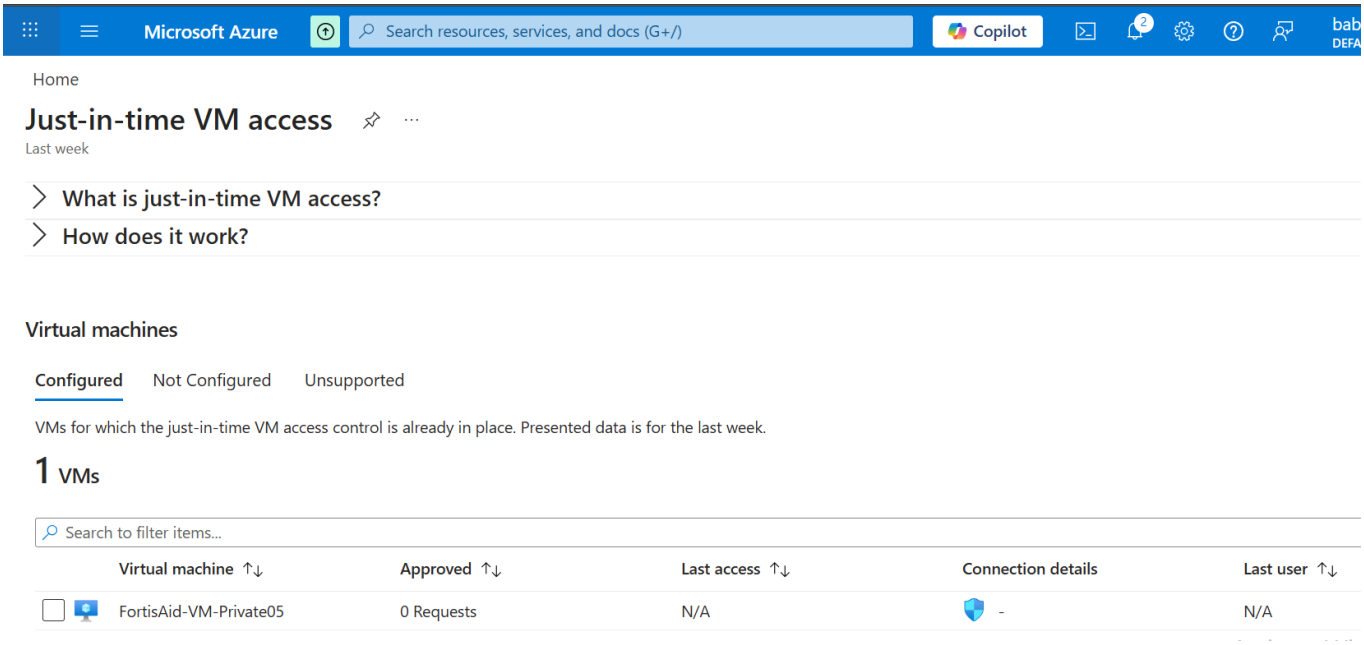
Not Configured tab showing FortisAid-VM-Private05

Step 3 – Enable JIT on the VM

1. Select checkbox for `FortisAid-VM-Private05`
2. Click **Enable JIT on VMs**
3. Configure management port:
   - Windows: 3389 (RDP)
   - Linux: 22 (SSH)
4. Configuration applied:
   - Protocol: TCP
   - Allowed source IP: My current public IP
   - Maximum access duration: 1 hour
5. Click **Save**

Verification

- VM moves to **Configured** tab



JIT Configured tab showing FortisAid-VM-Private05

Exercise 2 – Request Temporary Access

Step 4 – Initiate JIT Access Request

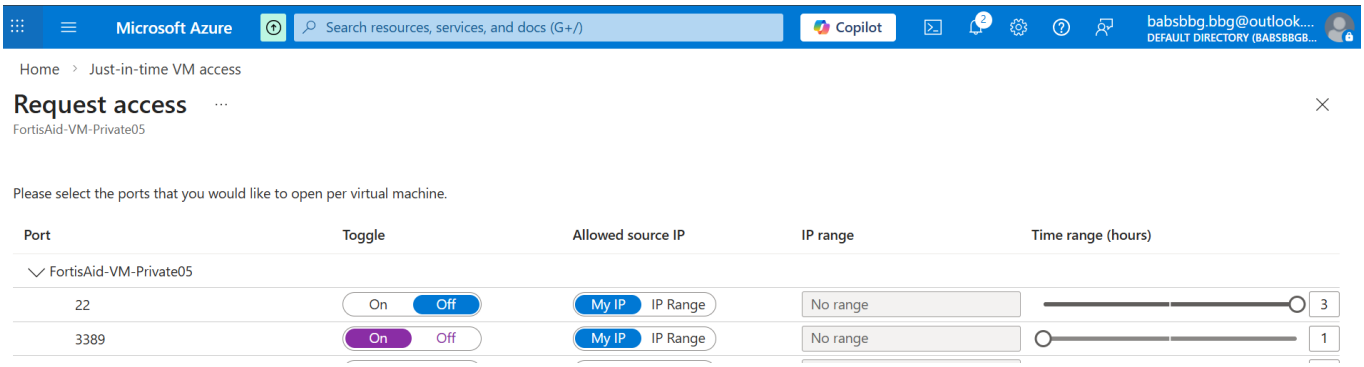
1. Under **Configured**, select `FortisAid-VM-Private05`
2. Click **Request access**
3. Specify:
   - Port: 3389 (or 22)
   - Source IP: My current public IP

- Duration: 1 hour

4. Submit request

Verification

- Request status = Approved



Request access panel showing Approved status

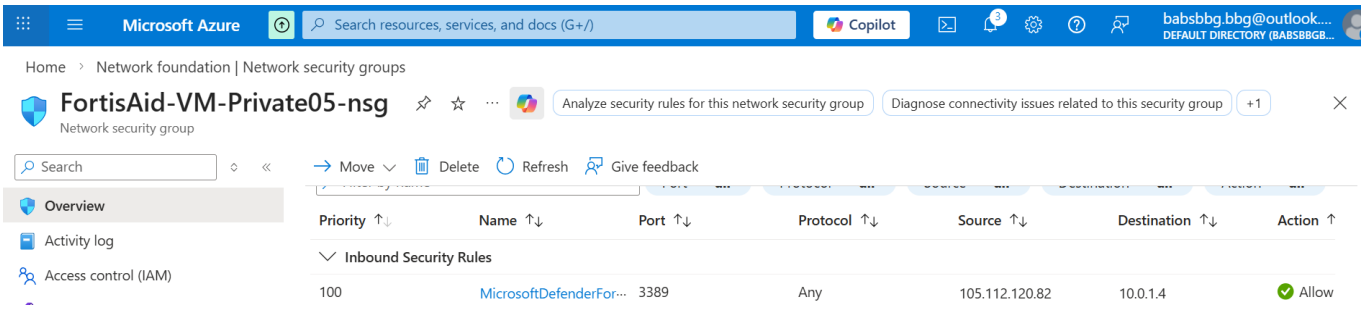
Step 5 – Validate NSG Rule Injection

1. Open VM → **Networking**
2. Select attached **Network Security Group**
3. Open **Inbound security rules**

Expected Behavior

- Temporary inbound rule created
- Rule limited to requestor IP
- Rule has expiration window

Verification



NSG inbound rule dynamically created by JIT

Step 6 – Confirm Automatic Rule Removal

After access window expires:

1. Refresh NSG inbound rules

Verification

- Temporary JIT rule removed
- Management port closed again

Security Engineering Validation

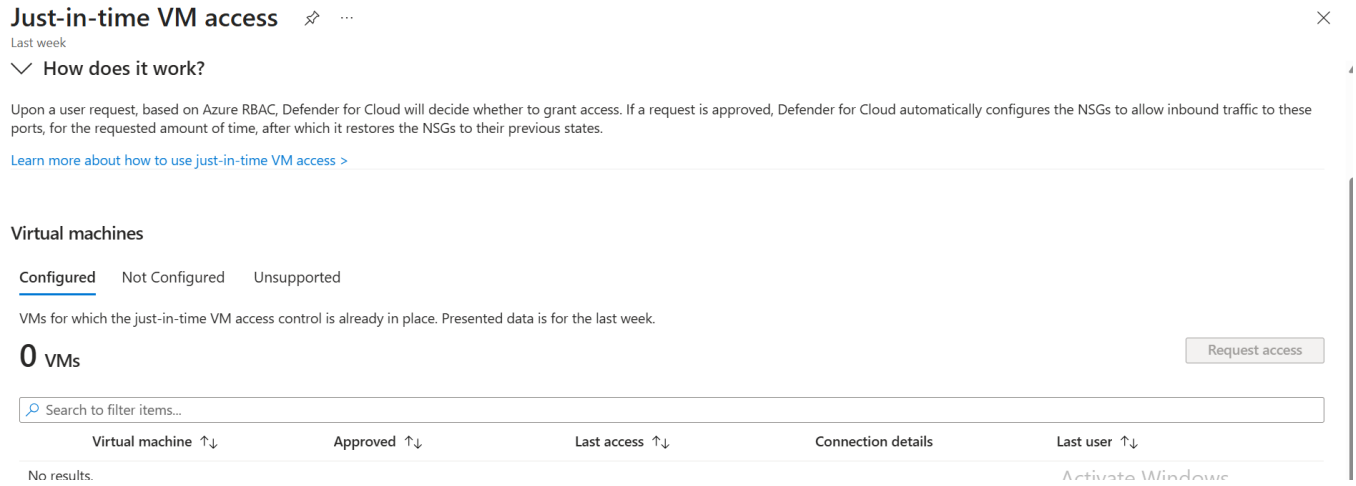
This implementation confirms:

- No permanently open RDP/SSH ports
- Time-bound, IP-scoped access enforcement
- Dynamic NSG manipulation by Defender control plane
- Reduced exposure to brute-force scanning
- Alignment with zero-trust access principles

Issues Encountered & Resolution

Issue 1 – JIT Initially Showed 0 VMs

Cause: VM had not yet been configured under Not Configured tab.
Resolution: Navigated to Not Configured tab and enabled JIT manually.



Issue 2 – Confusion Between Legacy and Modern JIT Paths

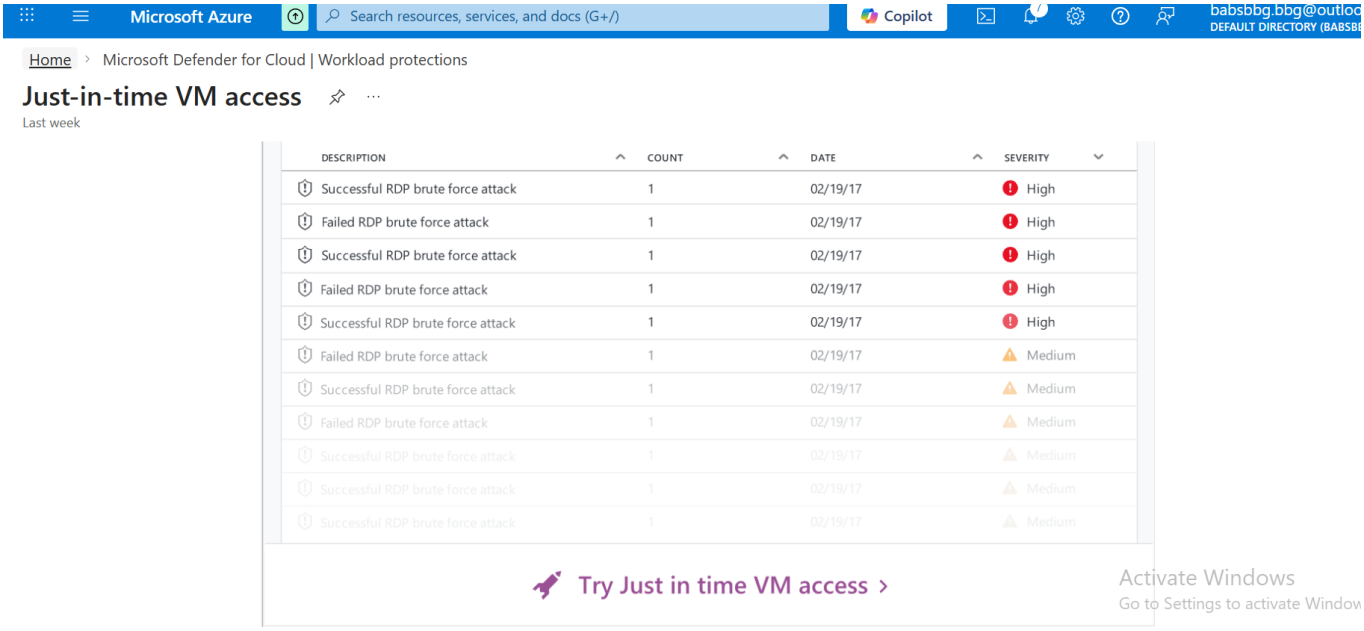
Microsoft Learn shows:

VM → Configuration → JIT

Modern Defender architecture requires:

Defender for Cloud → Workload protections → JIT blade

Resolution: Used modern control-plane path aligned with Defender Plan 2.



Issue 3 – Assumption That AMA Was Required

Initially expected Azure Monitor Agent extension to be installed.

Observation:

- Modern Defender Plan 2 operates in agentless mode.
- JIT functions without guest extension dependency.

Resolution: Validated agentless enforcement via NSG rule injection instead of extension presence.

Security Insight

JIT is not simply a convenience feature — it is a control-plane enforcement mechanism that:

- Converts static exposure into dynamic exposure
- Integrates with RBAC approval workflows
- Logs access requests for audit
- Automatically restores hardened posture

This is a measurable attack surface reduction control.